

## RESOLUTION FOR ARCHIVING OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following:

## FACTS

FIRST: The Spanish Agency for Data Protection became aware through the press of certain facts that could violate data protection legislation.

On January 26, 2024, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate for Data Inspection (SGID) to initiate the preliminary investigation proceedings referred to in Article 67 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD) to investigate ORANGE ESPAGNE, S.A.U. with NIF A82009812 (hereinafter, ORANGE) in relation to the following facts:

“As a result of news appearing in the media, this Agency has become aware of a possible security breach that may have affected the company Orange Espagne, S.A.U. and that may have left the information of many of its customers exposed and susceptible to being used for fraudulent purposes. Among the data that may have been exposed are the name, surname, postal address, telephone number, email, ID number, date of birth, nationality, and the IBAN code of the customers' bank accounts.

According to the published news, the company sent a communication to all possible affected parties to inform them of what happened, advising its users to exercise special caution over the following months with emails, messages, or calls whose origin or sender they could not confirm, especially those requesting banking information or credentials. It also warned its customers to regularly review the information circulating about them on the Internet to detect any possible fraudulent use of their private data.”

SECOND: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation proceedings to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following aspects:

The inspector obtained evidence from several news articles published in various media and social networks regarding a possible security breach suffered by ORANGE.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

From the analyzed news, the following relevant evidence stands out:

Several publications made on TWITTER through the account \*\*\*ACCOUNT.1 where evidence is disseminated of having obtained, as a result of public leaks, the credentials of ORANGE for access to RIPE NCC (European IP Networks Coordination Center), having managed to enter the application and make modifications to the routing system.

Several news articles published on different web portals about a sudden failure suffered by ORANGE that left many of its customers without connectivity and that resulted from the hijacking of ORANGE's account at RIPE NCC. From the published news, the following relevant statements for the investigation are extracted:

“The attack on Orange involved the manipulation of the Internet routing system known as BGP (Border Gateway Protocol). The attacker obtained Orange's credentials at RIPE NCC, allowing them to redirect the Internet traffic of Orange's customers, which caused failures when accessing websites and applications. This method is known as BGP hijacking. It involves taking control of online traffic routes to intercept the data flowing through them or, as in this case, redirecting them.”

“Orange has not provided details about this attack, but an unconfirmed theory suggests that the attacker stole the credentials of the account at RIPE NCC through a phishing attack on an employee of the operator in September 2023. This attack injected malicious software (infostealer) that allowed the attacker to obtain the username and password of that account. According to the published details, it was an extremely simple password lacking two-factor verification, which allowed the attacker to access solely with the password.”

Regarding the news published in various media, all refer to a possible attack suffered by ORANGE from which the access credentials to the company's RIPE NCC were leaked; however, none of these refer to the possible impact on personal data caused by this attack. The following publications are highlighted:

\*\*\*URL.1

\*\*\*URL.2

\*\*\*URL.3

In light of the doubts raised about the possible impact on personal data as a result of the security incident suffered by ORANGE, on March 5, 2024, a first request for information was made directed to this data controller and marked by the following line of investigation:

- Request the documented record of the incident and detailed information about the incident.
- Investigate the causes that made the incident possible, the possible impact on personal data, its possible leakage, and its consequences.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/5

On March 13, 2024, a response to the previous request was received, from which the following relevant information was extracted:

o

“The incident originated due to unauthorized access to the RIPE website by an unauthorized user. RIPE is a technical database that only contains technical administrative data related to telecommunications for routing internet traffic. Through RIPE, there is no access, either directly or indirectly, to personal data. Except for the RIPE application, the attacker did not gain access to any of the applications whose credentials they might have obtained. They did not access the content of the infected PC, nor the information that could be found on it.”

o

“The applications whose credentials may have been obtained are of a technical nature, containing information on deployments, reconfigurations, network infrastructure, etc., without providing access to personal information. There is no evidence of unauthorized access; there is no evidence that any of the obtained credentials were used; in the applications, there are no spikes in activity, following a normal activity pattern of the service.”

o

“There has been no security breach in the terms of Article 33 of the GDPR. The incident was managed as a service incident, as its availability could have been affected, transferring a technical report to the Secretary of State for Telecommunications and Digital Infrastructures in accordance with Article 22 of Order IET/1090/2014, of June 16, which regulates the conditions relating to service quality in the provision of electronic communications services.”

They indicate the chronology of events with the most significant milestones of the incident:

o

On January 3, 2024, with information published on the internet, it was detected that the origin of the RIPE password leak was from a PC of an ORANGE provider, dated September 4, 2023, due to an infection by the RACCOON stealer (malware designed to track and obtain sensitive information from a PC).

o

On January 4, 2024, information about the leak was obtained, and an internal investigation began,

ruling out that any other compromised credentials could have been used fraudulently. On this same date, the affected PC was located.

o

On January 8, 2024, ORANGE commissioned a forensic report of the PC from the specialized company ZEROLYNX.

o

On January 18, 2024, ORANGE received the forensic report, which confirmed the infection of the PC on September 4, 2023, detecting that the malware accessed the information contained in the folder "\*\*\*\*FOLDER.1" where the information about the password cache of the browsers was stored, stating that no evidence of access to information outside of that folder was found.

They state that, according to the forensic report, the malware accessed the information of the PC: (...).

They indicate that:

"The forensic analysis concluded that the user of the device downloaded on September 4, 2023, at 10:12:20 a file named 'KMSPICO.rar' that contained Stealer-type malware. At 10:12:59, they extracted and executed it. The malicious application would have collected different information from the user by accessing the path '\*\*\*\*PATH.1' where the user's web browsing profile information is stored, including the cache of credentials stored in the browsers. There is no evidence of access by the malware to other folders on the device. There are indications that the malware was stopped by Windows Defender and quarantined at 10:14:29."

The Data Inspector concludes that there is no other evidence of possible impact on personal data, so the security incident cannot be considered a security breach.

## LEGAL GROUNDS

I

### Competence

In accordance with [Insert the corresponding text for [Text ground I EI].] and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to resolve these investigative proceedings.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

### Conclusion

It has been established that ORANGE suffered a security incident on September 4, 2023, caused by the entry of the RACCON malware (malicious code that seeks to collect and exfiltrate information stored in the

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)

5/5

equipment) on one of the PCs of one of its suppliers. According to the company's assertion, it is confirmed that this malware managed to access several files in the AppData folder where the password cache of the browsers was stored, leaking several credentials of ORANGE from technical applications, which contained information about deployments, reconfigurations, network infrastructure, etc., without having been able to access personal data through them.

Since it has not been established that the security incident suffered by Orange constituted a breach of personal data, there have been no events that fall within the jurisdiction of the Spanish Agency for Data Protection.

In accordance with the above, the Director of the Spanish Agency for Data Protection, IT IS AGREED: FIRST: TO ARCHIVE the present proceedings.

SECOND: TO NOTIFY this resolution to ORANGE ESPAGNE, S.A.U.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided for in Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions of Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

940-301023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

[www.aepd.es](http://www.aepd.es)

28001 – Madrid

[sedeagpd.gob.es](mailto:sedeagpd.gob.es)